Global Logistics Corp GenAIOps Operating Model

Seven-component operating model for regional generative AI under centralized governance

Prepared by Dennis, GenAIOps Lead, for the GLC executive leadership team · 13 October 2026 · Main body 3,866 words (assumptions page and Components 1–7, including tables); appendices, references and diagrams excluded · All volumes, rates and thresholds are illustrative course inputs

Assumptions and constraints

This package covers four workloads (GLC-CX-Chat, GLC-NetAssist, GLC-DocSum and GLC-ExceptionAgent) across the EU, Brazil, India and the United States. Token rates stay at the illustrative USD 2.50 input and USD 10.00 output per million tokens until FinOps loads contracted SKU rates. Agent tokens per task are a bottom-up estimate; 5×, 12× and 30× are sensitivity checks only. Where the brief is silent, this design assumes that 40% of chats are status or FAQ intents, 27% of documents are templated forms, peak traffic is three times the monthly average, and the agent launches in the EU and US first. Brazil and India exception cases stay with human teams until a regional agent stack and legal review are complete. Four constraints from the brief apply throughout: no action executes without an application identity, a user or service identity, a policy result and a trace ID; raw prompts and responses are not retained by default; a content-safety result never grants action permission; and preview features need explicit acceptance and a production fallback.

EU AI Act position. The agent's intended purpose, rerouting shipments and granting service credits, is not an Annex III use case, so financial consequences alone do not make it high-risk. GLC-CX-Chat talks directly to customers, so the Article 50 transparency duty, applicable since 2 August 2026, requires telling them they are using AI. Regulation (EU) 2026/1744 sets 2 December 2027 as the application date for the Annex III high-risk requirements in Chapter III, Sections 1–3; the Commission's 2026 classification guidelines remain guidance, and their final status must be checked at deployment. Oversight, logging, testing, authority limits and incident controls apply whatever the final classification. **Legal owner:** AI Regulatory Counsel. **Privacy owner:** the Data Protection Officer (DPO), who owns the GDPR DPIA, the LGPD impact report and the DPDP assessment. **Reassessment triggers:** creditworthiness or credit scoring of natural persons, decisions on access to essential services, profiling for an Annex III purpose, use as an Annex I safety component, new jurisdictions, higher authority thresholds, and an annual review.

Table 1. Assumption register (Day 1 = 2 November 2026)

Assumption	Value or decision	Validation owner and date
Model rates	USD 2.50 / 10.00 per 1M tokens; replace with contracted SKUs	FinOps lead, 11 Nov 2026
Agent tokens per task	21,590 base (7,810 low; 60,050 high) until traces replace it	AgentOps lead, 6 Dec 2026
Deployment boundary	Data Zone EU/US; regional Brazil and India; Global only for non-personal NetAssist data	Platform engineering + DPO, 21 Nov 2026
Retention	Record-class schedule RC1–RC6 (Table 7)	DPO + AI Regulatory Counsel, 26 Nov 2026
Incident targets	Course defaults: SEV1 acknowledge ≤ 15 min, contain ≤ 30 min	Security incident manager, 16 Dec 2026
Budget	USD 50,000 a month; 25% reduction target	CFO delegate, 11 Nov 2026

Component 1: Operating model overview and executive summary

Executive outcome. Global Logistics Corp (GLC) runs customer chatbots, internal assistants and an exception agent that can reroute shipments and issue credits for a 200,000-person business in 50 countries. Because these systems touch customers, money and personal data under four privacy regimes, a loose set of policies and scripts is not enough. This operating model shows leadership how GLC will govern usage, manage cost, protect people and operate agents safely at scale. It covers 2.86 million AI tasks a month and commits to three outcomes: a 25% lower model bill at equal quality, faster exception handling through bounded autonomy, and audit-ready evidence for every agent decision.

Most important design decision. Every model call and every agent action passes through one logically centralized policy enforcement plane, deployed as regional gateway units so that no single region is a point of failure. The plane routes each request to a deployment that matches the data's jurisdiction: EU and US Data Zone Standard for personal data, regional deployments in Brazil and India, and Global Standard only for NetAssist's non-personal operational data. Model processing is only half the boundary, so the search index, storage, thread store and Application Insights for each workload stay in the same geography and are verified at every release.

Authority design. GLC-ExceptionAgent proposes; the Action Policy Service decides. The agent holds no write credentials. It may auto-execute only service credits up to USD 250 and reroutes up to USD 1,000 that meet every scenario condition. Everything else needs recorded human approval, and customs, sanctions, dangerous-goods, personal-data and data-boundary decisions are human-only (Figure 4). Nobody can approve an action they requested, and approvals above USD 2,500 need two different people from Finance and Legal.

Operating loop. Governance sets policy. FinOps, safety and privacy, and AgentOps turn it into quotas, filter profiles and authority limits that the plane enforces. Evidence lands in regional stores, drives incident response and improvement, and returns to governance as change requests and maturity evidence (Figure 1).

Table 2. Success metrics

Metric	Target	Owner	Data source
Model-cost reduction	≥ 25% below the USD 22,697 monthly base with ≤ 2-point quality decline	FinOps lead	Cost Management reconciliation; evaluation suite
Agent autonomous resolution	55–70% of exception cases resolved within auto-execute limits, 0 approval-gate bypasses, ≥ 99% approved-action success	Agent product owner	Decision-attribution records
Audit completeness	≥ 99.5% decision-record completeness; ≥ 98% of model spend allocated	Platform engineering + DPO	Application Insights query; monthly reconciliation

The 55–70% range is an assumption to confirm from the first 30 days of traces. Critical containment within 30 minutes is tracked as a control target in Component 4.

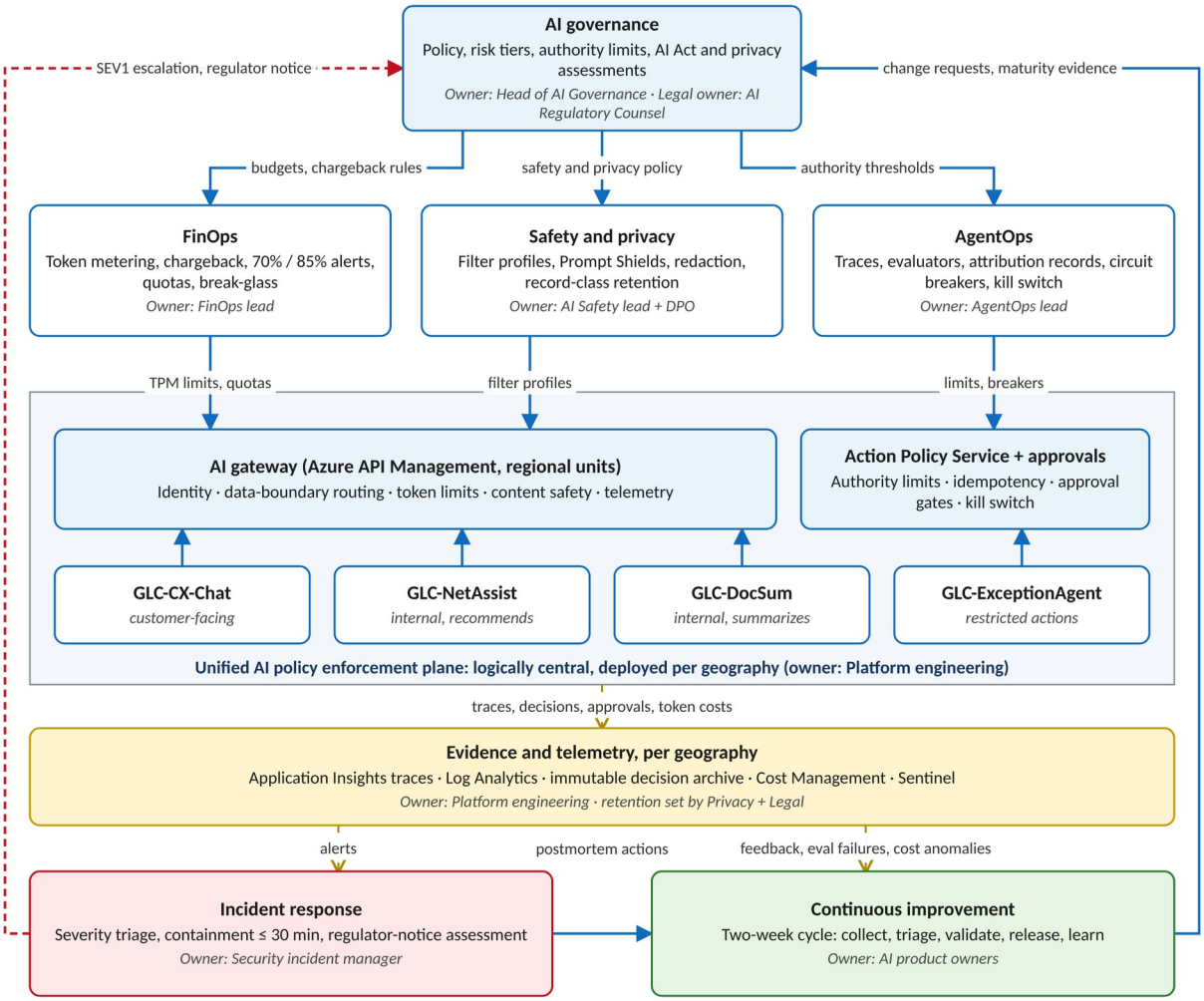


Figure 1. Operating model loop with owners and evidence flows

Component 2: FinOps governance framework

Cost model. The workbook multiplies monthly tasks by input and output tokens per call, calls per task and the illustrative rates. The base-case portfolio costs USD 22,697 a month, 45% of the USD 50,000 budget (Appendix A). GLC-CX-Chat is the largest line at USD 9,500 and already uses 79% of its budget, above the 70% alert.

Agent cases. Agent cost is built from model calls, tool context, retries and outputs (Table 3), with the course multipliers kept as a cross-check.

Table 3. Exception-agent cost cases (60,000 tasks a month)

Driver	Low	Base	High
Model calls per task; retry rate	3; 0%	5; 10%	8; 30%
Tool-schema tokens per call	600	1,200	2,000
Instructions, case context and tool results per call	1,800	2,500	3,500
Input / output tokens per task	7,200 / 610	20,350 / 1,240	57,200 / 2,850
Monthly cost	**USD 1,446**	**USD 3,797**	**USD 10,290**
Equivalent multiplier (sensitivity case cost)	5.1× (5×: USD 1,425)	13.3× (12×: USD 3,420)	36.1× (30×: USD 8,550)

Two findings shape the controls. Tool schemas are 32% of agent input tokens, so pruning them is the cheapest agent saving. The 30× stress case understates a plausible runaway by USD 1,740 a month, so a 45,000-token ceiling per task (about twice the base case) stops a run and hands the case to a human.

Agent measurement. Foundry tracing records input and output tokens, tool calls and retries for each span in Application Insights; GLC's instrumentation adds tool-schema and cached token counts to each run. The planning estimate retires on Day 35, once 30 days of traces and at least 10,000 runs show P50 and P95 tokens per task stable within ±10% week over week. The measured P50 then becomes the base case.

Allocation. The chargeback unit is cost per resolved task: per conversation, summary or exception case. Spend is tagged by application ID, subscription, region, model SKU, deployment type and cost center. The gateway emits token metrics with these dimensions, and FinOps reconciles them monthly to Azure Cost Management, because gateway counters are not the financial ledger. Target coverage is 98% of spend.

Controls. Alerts fire at 70% (owner and FinOps notified) and 85% (optimization or exception plan required). Token-rate limits sit at three times average demand: 160,000 tokens per minute (TPM) for chat, 130,000 for DocSum, 90,000 for the agent and 50,000 for NetAssist. Hard monthly quotas apply only where a cut-off is business-safe: NetAssist and the DocSum batch lane. Chat shifts eligible intents to the lower-cost tier instead of stopping, and the agent sends new cases to the human exception queue. Break-glass exceptions last at most seven days, with a named owner and automatic expiry.

Table 4. Optimization tactics tied to the 25% target

Tactic	Baseline and change	Saving a month (range)	Owner	Guardrail; verification
T1 Model routing	Chat status and FAQ intents (40%), templated documents (27%) to a lower-cost tier	USD 4,100 (2,700–5,200)	Platform engineering lead	≤ 2-point drop per intent; A/B evaluation
T2 Prompt and tool-schema reduction	Instructions trimmed 5%; agent schemas 1,200 to 600 tokens a call	USD 1,234 (700–1,700)	AgentOps lead	0 new safety failures; trace token breakdown
T3 Retry and output caps	Agent retries 10% to 3%; NetAssist output 600 to 450 tokens	USD 617 (300–900)	AgentOps lead	No completion loss; retry count
Combined	Applied in sequence per workload; chat falls to 53% of its budget	**USD 5,951 (26.2%)**		Caching waits for contracted cached-input pricing

Component 3: AI governance architecture

Identity and authorization. Employees sign in with Microsoft Entra ID, MFA and Conditional Access; customers use Entra External ID scoped to their own shipments. Each application and the agent run under their own managed identity with no stored keys. Administrator roles are eligible-only through Privileged Identity Management (PIM) and reviewed quarterly. Table 6 is the access-control matrix.

Policy enforcement plane. Azure API Management (APIM) is the AI gateway, with regional units in the EU, US, Brazil and India and policies deployed from one Git repository (Figure 2). Every request passes six steps: authentication; app-to-deployment authorization; a data-boundary check that denies requests whose case geography differs from the deployment zone; schema validation and token limits; content filters and Prompt Shields; and trace emission. A failed regional unit fails over only within its geography, and agent actions fail closed. The Action Policy Service is a separate deterministic decision point and the only identity that can write to the transport management system (TMS), billing and carrier APIs. It rejects any action that lacks an application identity, a user or service identity, a policy result or a trace ID.

Table 5. Deployment-boundary decision (Global versus Data Zone)

Workload	Decision	Reason
CX-Chat, DocSum	EU and US Data Zone Standard; Brazil South regional, else US zone with ANPD standard clauses; Central India regional, or APAC zone after DPDP review	Customer, shipment and customs personal data
ExceptionAgent	EU and US Data Zone with same-geography connected services; Brazil and India human-handled for now	Decisions on personal data; limits cross-border risk
NetAssist	Global Standard; gateway denies requests with personal data	Non-personal operational data; highest capacity

Data Zone processing can occur anywhere in the zone, so workloads with a single-country obligation use regional deployments.

Table 6. Access-control matrix (U use · A approve · O operate through PIM · R read redacted telemetry · K kill switch)

Identity	CX-Chat	NetAssist	DocSum	ExceptionAgent	Evidence
Customer (External ID)	U, own shipments	—	—	—	—
Network planner; document clerk	—	U (planner)	U (clerk)	—	—
Exception analyst	—	—	—	U	R
Operations manager	—	—	—	A up to USD 2,500	R
Finance and Legal approvers	—	—	—	A above USD 2,500, dual	R
Customs and trade specialist	—	—	—	A human-only cases	R
Platform engineer	O	O	O	O	R
AgentOps lead; Security incident manager	R, K	R, K	R, K	R, K	R; raw vault with DPO approval
DPO; internal audit	R	R	R	R	R; DPO approves raw vault and holds
FinOps analyst	Cost	Cost	Cost	Cost	Cost data
Application managed identities	Own deployments in own geography only				
Agent managed identity	Model deployments and Action Policy Service; no business-system write				
Action Policy Service identity	Writes TMS, billing and carrier APIs for approved actions only				

People are scoped to their own geography. Global roles see metadata from every geography but content only in-region.

Audit record. Each model call and action writes a trace keyed by trace ID: application, caller identity, policy result, deployment, region and data zone, model and prompt versions, token counts, latency and content-safety results. Agent decisions add the attribution fields in Table 10. Content is redacted or hashed; raw prompts and responses are not kept by default.

Table 7. Record-class retention schedule

Record class	Retention	Storage	Access
RC1 Operational traces (metadata)	90 days	Log Analytics, per geography	Platform, AgentOps
RC2 Decision and approval records	7 years if executed; 13 months if not	Immutable Blob (WORM), per geography	Audit, Legal, DPO
RC3 Security evidence	2 years	Microsoft Sentinel	Security operations
RC4 Redacted QA samples	30 days	Regional evaluation store	QA reviewers
RC5 Raw content capture	Off; ≤ 30 days for a DPO-approved incident	Restricted vault, customer-managed key	Named investigators
RC6 Cost aggregates	25 months	FinOps dataset	FinOps

Lifecycle policies delete expired records and log each deletion job. Erasure requests delete the pseudonym mapping in the source system, so archived records can no longer identify a person. A legal hold, set and released only by AI Regulatory Counsel, suspends deletion for scoped records. Seven years assumes GLC's financial-record retention, which AI Regulatory Counsel confirms per jurisdiction, and exceeds the six-month log minimum that would apply if the agent became high-risk.

Deployment governance. Changes to a model, prompt, tool, safety configuration, authority threshold or data processing need AI governance council approval with evidence: evaluation and red-team results, an updated DPIA, a data-boundary test and a rollback plan. Preview features need written risk acceptance and a generally available fallback.

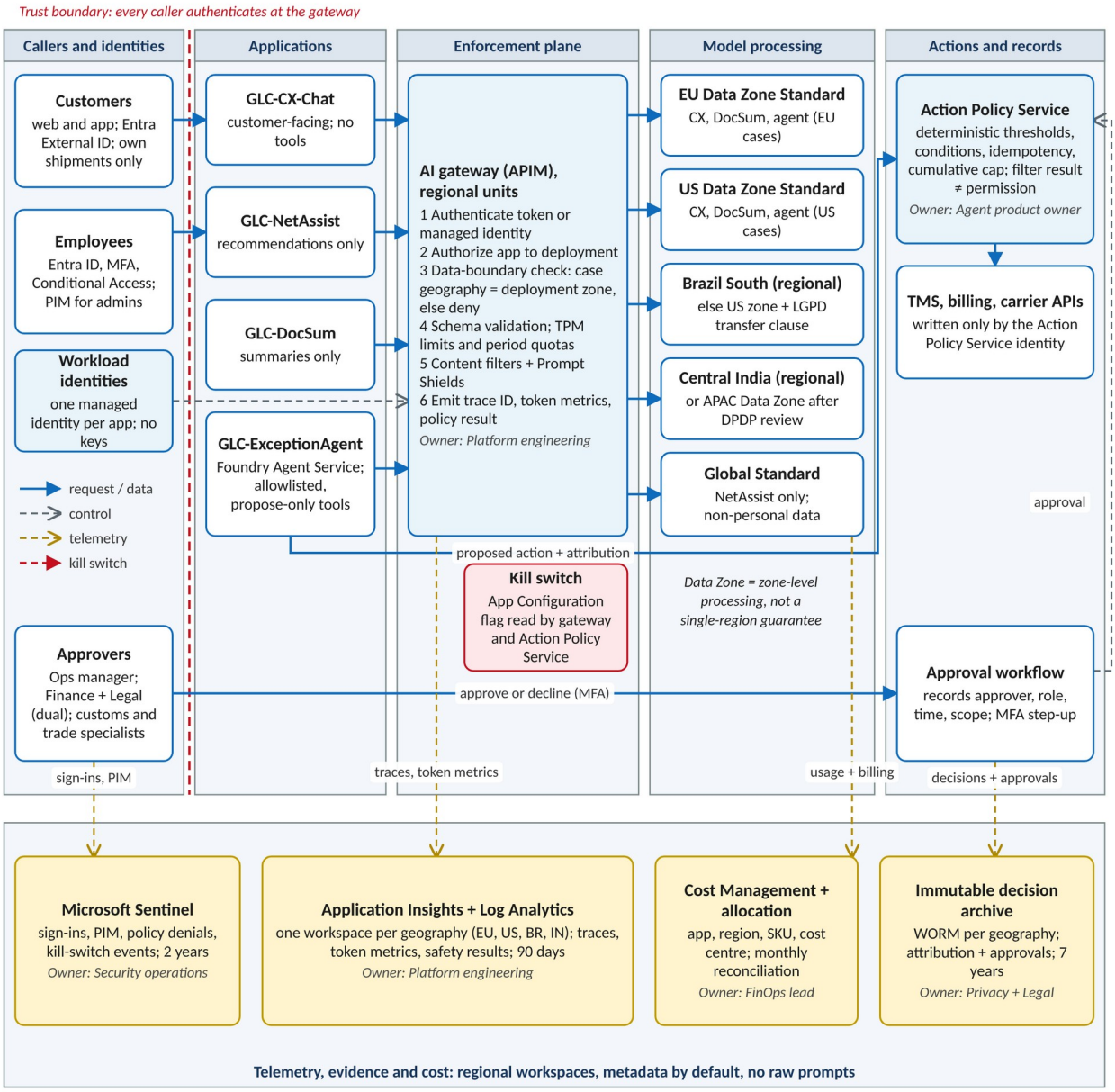


Figure 2. Unified AI gateway: trust boundary, identities, regional routing, policy decisions, telemetry and systems of record

Component 4: Content safety operations

Safety profiles tighten as exposure and authority grow (Table 8). A content-filter or Prompt Shields pass never grants permission to act; only the Action Policy Service can.

Table 8. Differentiated safety profiles

Control	CX-Chat (external)	NetAssist	DocSum	ExceptionAgent
Input filter blocks at	Medium	Medium	Medium	Medium
Output filter blocks at	Low	Medium	Medium	Low
Prompt Shields	User prompts	User prompts	Documents	Prompts and documents
Personal data	Redacted in logs; AI disclosure	Denied at gateway	Protected handling	References only
Tools	None	None	None	Allowlist, parameter checks, ceilings, breaker
Rate limit	20 requests a minute per user; 8,000 tokens a session	TPM	TPM; batch quota	45,000 tokens a task
QA sample	1%	1%	2%	5%

Chat and the agent block outputs at low severity because a harmful answer reaches a customer or triggers an action; inputs block at medium so that frustrated but legitimate customers are not refused. Customs documents and carrier emails are the main indirect-injection path, so DocSum and the agent check every attachment with Prompt Shields and quarantine flagged sources. Chat opens each session by saying the customer is talking to an AI assistant and offers a human handoff, meeting Article 50(1).

Incident severity and escalation. Severity follows business and regulatory impact (Table 9, Figure 3), and Appendix C sets what first-line operators may do before they hand over. The DPO and AI Regulatory Counsel decide on notification within statutory clocks: GDPR 72 hours, LGPD three working days, DPDP 72 hours once in force, and applicable US state rules. These targets are course defaults that GLC must adapt after the Day 20–45 exercise. Every SEV1 and SEV2 gets a postmortem within five business days.

Table 9. Incident severity and escalation matrix

Severity	Example triggers	Acknowledge	Contain	Incident lead	Notify
SEV1	Action executed without approval; personal data to the wrong customer or across a boundary; harmful output at scale	≤ 15 min	≤ 30 min	Security incident manager	DPO, Legal, COO delegate within 1 hour
SEV2	Isolated harmful output; repeated boundary denials; cost above twice daily baseline; evaluator failures > 5%	≤ 30 min	≤ 4 hours	AgentOps lead	Workload owner; DPO if personal data
SEV3	Quality drop > 2 points; internal quota breach	≤ 4 business hours	≤ 5 business days	Product owner	FinOps or AgentOps
SEV4	UX defects; false-positive blocks	Next cycle	Next cycle	Product owner	None

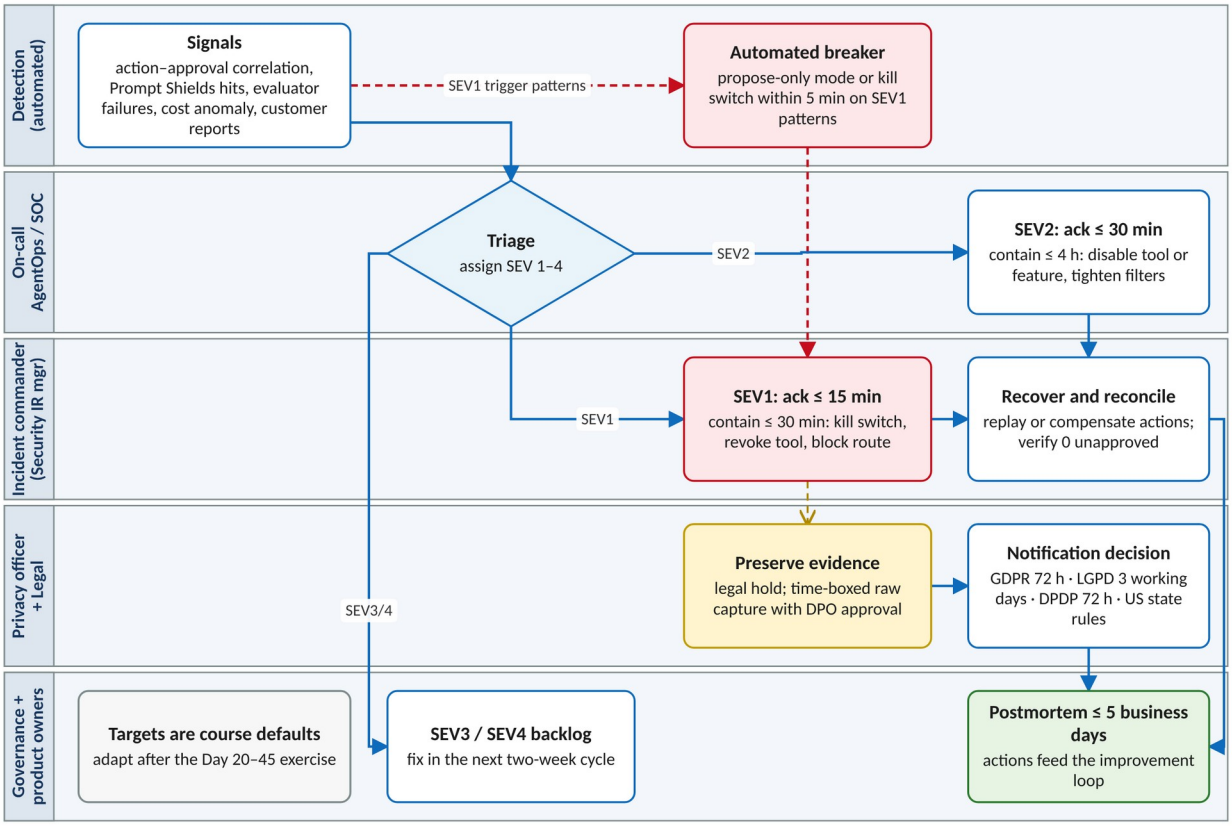


Figure 3. Incident escalation flow by role

Component 5: AgentOps framework

Trace and metrics. The agent emits OpenTelemetry GenAI spans to Application Insights through Foundry tracing, which is generally available for prompt and hosted agents; workflow and external agents are preview and not used. Each run records model and tool steps, retries, tokens, latency, cost, policy rules, approvals, actions, errors and compensation.

Evaluation. Deterministic rule outcomes are the production gate. Foundry's task-adherence, intent-resolution and task-completion evaluators are preview, so they score sampled traces as advisory signals. Thresholds:

- Confidence below 0.80 sends the case to human review, even under USD 250.
- Evaluator failures above 5% of sampled runs in 24 hours switch the agent to propose-only mode.
- Auto-executed credits above twice the seven-day hourly baseline open the circuit breaker.
- Exceeding 8 model calls, 2 retries per tool or 45,000 tokens ends the run and escalates it.

Attribution. Each decision record maps the trace ID to agent and service identities, an input snapshot reference (hash and redacted pointer), evidence references, model, prompt and policy versions, rules with reason codes, confidence, proposed action, approval, execution with idempotency key, and any human override (Table 10). Completeness is measured daily against the 99.5% target.

Table 10. Sample decision-attribution record

Field	Value
trace_id; decision_id	4bf92f35…; EXC-2026-11-000184
Versions	GLC-ExceptionAgent 1.4; prompt v12; policy v7; deployment dz-eu (EU Data Zone)
Identities; policy result	Application GLC-ExceptionAgent; service identity mi-exc-agent-eu (event-triggered, no user); policy result allow
Input snapshot; evidence	sha256:9c1e…, redacted pointer arc://eu/exc/000184; shipment token SHP-7Q2X, carrier scan, policy SLA-EXP-48
Proposed action; confidence	Service credit USD 180; 0.91
Rules and reason codes	POL-CR-01 pass (≤ USD 250); FRAUD-00 pass; DISPUTE-00 pass; CUM-30D pass (USD 180 of 500); IDEMP pass
Safety results	Input and output filters pass; no Prompt Shields detection
Approval; execution	Not required (auto-execute tier); billing API 201, idempotency key 7f3a…, 2026-11-14T09:42:07Z
Override; record class	None; RC2, 7 years, EU archive

Table 11. Failure controls

Failure mode	Trigger	Automated response	Owner	Recovery condition
Tool failure	> 10% tool errors in 15 minutes	Breaker opens; propose-only; cases queued	AgentOps on-call	Errors < 2% for 30 minutes
Repeated retry	> 2 retries per tool or ceiling hit	Run stops; case escalates with record	AgentOps on-call	Ceiling hits < 3% of weekly runs
Data-boundary mismatch	Case geography differs from deployment zone	Gateway denies; SEV2	Platform engineering + DPO	Boundary test passes
Policy bypass	Executed action without matching approval (5-minute correlation)	Kill switch; SEV1	Security incident manager	All actions reconciled; council approval
Safety violation	Prompt Shields hit or blocked output	Run ends; source quarantined; human handles	AI Safety lead	Source cleared; > 5 an hour is SEV2
Downstream outage	TMS, billing or carrier API unhealthy	Actions queued with idempotency keys; partials compensated	Integration owner	System healthy; queue reconciled

Evidence for each row is the breaker, gateway or correlation log plus the incident ticket.

Human accountability. Approvals record approver, role, timestamp, decision and scope (amount, shipment and expiry). The agent never auto-denies; declines and non-matches go to the human exception queue (Figure 4). A cap of USD 500 in auto-executed credits per customer every 30 days stops a large credit from being split under the USD 250 limit. Customers can dispute any decision through customer service; an operations manager who was not involved reviews it within 10 business days, supporting LGPD Article 20 review rights and GDPR Article 22 safeguards. Overturned decisions feed the improvement loop.

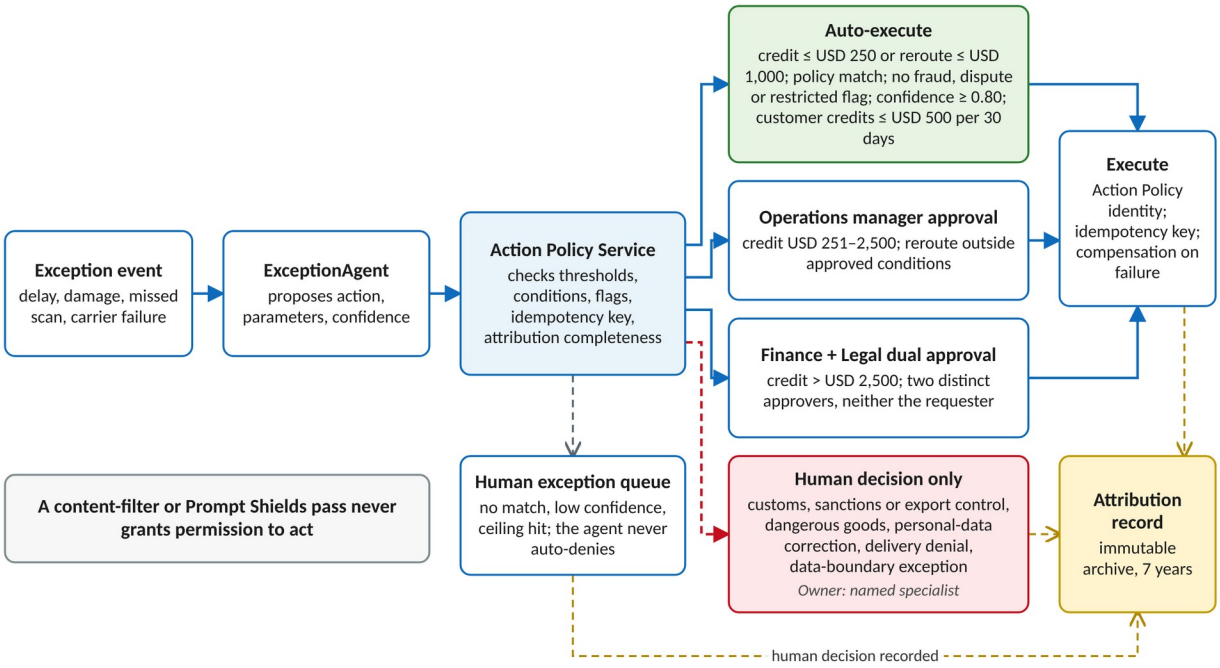


Figure 4. Exception-agent authority and attribution flow

Component 6: Continuous improvement process

Improvement runs in two-week cycles with a safety gate (Figure 5).

Collect. Sources are in-app ratings with reason codes, a QA sample queue (1% of chat and NetAssist sessions, 2% of summaries, 5% of agent runs), incident findings, evaluator failures, cost anomalies, operator and approver feedback, and quarterly business reviews. Items are redacted and de-duplicated on intake.

Triage. Product owners classify each item as prompt or policy, retrieval content, model, tool, UX, data or incident remediation and assign a risk tier. Safety and privacy items move to the front of the queue.

Validate. Candidates run the approved evaluation suite. The safety gate passes only with a task-quality drop of 2 points or less, zero critical safety or privacy failures, at least 98% of the attack set blocked, cost per task no more than 5% higher unless approved, and P95 latency within its service-level objective (SLO).

Release. Approval follows the risk tier: product owner for UX changes, plus AgentOps for prompt, retrieval or routing changes, and the AI governance council with Privacy and Legal for model, tool, authority, safety or data changes. Rollout goes to 5%, 25% and then 100% of traffic, 48 hours per step, with automatic rollback on any SLO breach.

Learn. Teams update runbooks, tests, policies, training and maturity evidence, and each closed item records the evidence that closed it. That closure record fixes the Developing-stage gap where feedback reached teams but was never verified.

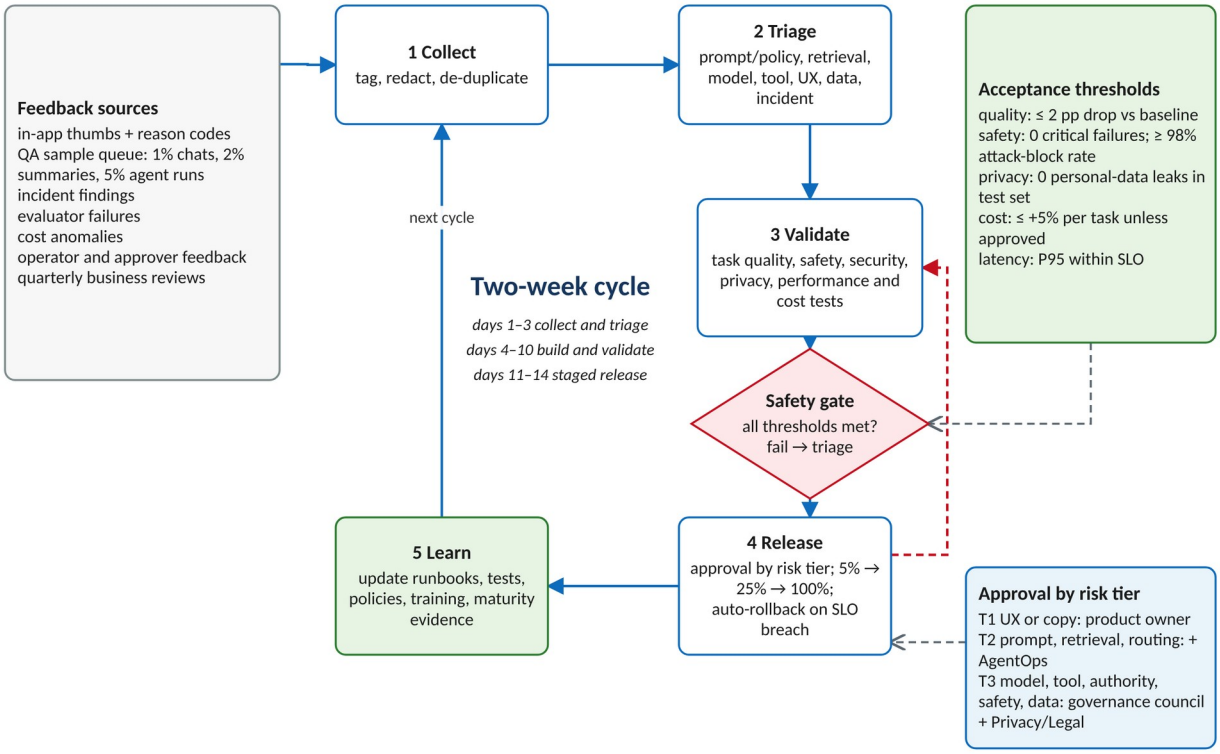


Figure 5. Continuous improvement loop with safety gate and approval tiers

Component 7: Maturity assessment and 60-day plan

GLC sits at Developing: policies exist but are unevenly enforced, agent costs are estimated, decision records and retention vary by team, agent safety tests and runbooks are incomplete, and feedback closure is unverified. The 60-day goal is Defined: one enforced policy plane, trace-based cost, standard records and tested incident response. The five candidate initiatives stay, ordered by risk. Initiative 1 closes the highest-impact exposures, unenforced policy and unauthorized actions; initiative 2 supplies the records that 3 and 4 depend on; initiative 5 makes the controls durable.

Table 12. Top five gaps and 60-day plan

#	Gap and initiative	Owner	Window	Acceptance criterion and evidence (dependency)
1	Uneven enforcement: gateway for every workload; agent action policy and kill switch	Agent product owner + Security	Days 1–15	100% of model calls through the gateway and 100% of executable tools behind the Action Policy Service; 0 bypasses in a 7-day correlation; kill-switch drill contained ≤ 30 min
2	Inconsistent records: standard attribution records and retention	Platform engineering + DPO	Days 1–25	≥ 99.5% completeness over 7 days; raw capture off; RC1–RC6 policies deployed
3	Estimated cost: token metering and allocation	FinOps lead + Platform engineering	Days 10–35	≥ 98% of spend mapped and reconciled; multiplier replaced by trace P50 (needs 2)
4	Untested response: incident exercise	Security incident manager + DPO	Days 20–45	SEV1 drill acknowledged ≤ 15 min, contained ≤ 30 min; notification decision tested (needs 1, 2)
5	Unverified feedback: risk-tiered change and evaluation gates	AI governance council + AI Regulatory Counsel	Days 30–60	Every Tier 3 change has evidence and rollback; 200-case agent attack suite ≥ 98% blocked; intended-purpose assessment and DPIA signed (needs 1–4)

Dependencies. Initiatives 1 and 2 run in parallel because different teams own them. Reconciliation in initiative 3 needs the application, region and SKU tags that initiative 2 adds to every record. The exercise in initiative 4 must use the real kill switch from initiative 1, and initiative 5 needs evidence from all four. If initiative 1 slips past Day 15, the agent stays in propose-only mode until its drill passes.

Three quick wins land in the first two weeks: switch off raw-content capture, turn on the 70% and 85% budget alerts (chat already exceeds 70%), and enforce the 45,000-token task ceiling. The AI governance council reviews progress weekly, and an item closes only when its evidence is filed in the immutable archive.

Appendices: adapted course resources

The four appendices adapt the course resources to GLC. They keep each template's structure and columns; the sample content in the shared-responsibility, Tier 1 and scenario-data templates came from other course scenarios and has been replaced with GLC data.

Appendix A: GenAIOps cost model

Workload	Tasks a month	Tokens a task (in / out)	Base cost (USD)	Budget used	TPM limit	After T1–T3 (USD)
GLC-CX-Chat	2,000,000	900 / 250	9,500	79%	160,000	6,318
GLC-NetAssist	300,000	1,800 / 600	3,150	39%	50,000	2,574
GLC-DocSum	500,000	3,000 / 500	6,250	42%	130,000	4,750
GLC-ExceptionAgent	60,000	20,350 / 1,240	3,797	25%	90,000	3,105
Total	**2,860,000**		**22,697**	**45%**		**16,746**

Source: Dennis_GenAIOps-Cost-Model.xlsx, the completed course workbook. Added sheets: Agent Bottom-Up (low, base and high cases with the trace field that replaces each assumption), Workload Optimization (T1–T3 applied in sequence) and Quota Plan (TPM limits, behaviour at 100% and per-task caps). The agent base multiplier now links to the bottom-up case; 5×, 12× and 30× remain on the Agent Sensitivity sheet. Rates are illustrative.

Appendix B: Shared responsibility and control evidence

ID	Control and intent	Microsoft	GLC (customer)	Partner	Owner / operator	Evidence; cadence; due
CTRL-01	Identity: workloads authenticate without stored secrets	Entra ID and managed identity platform	Managed identity per app and agent; least-privilege RBAC; no client secrets	Carriers protect their API credentials	Identity and Security / Platform eng.	Role assignments, sign-in logs; quarterly; Day 15
CTRL-02	Privileged access: time-bound elevation	Entra ID, PIM and Conditional Access capability	PIM, MFA, quarterly access reviews, break-glass accounts	Name contacts; remove leavers	Identity and Security / Security ops	PIM activations, review records; quarterly; Day 15
CTRL-03	AI gateway: every model call passes policy	APIM gateway and policy engine	Policy as code; six checks; regional units with in-geography failover	—	Platform eng. lead / Platform ops	Policy versions, denial logs; per release; Day 15
CTRL-04	Data boundary: processing stays in the approved zone	Data Zone and regional processing as documented	Choose deployment type per workload; pin connected services; deny mismatches	Carrier data-sharing terms	DPO + Platform eng. / Platform ops	Deployment inventory, boundary test; per change; Day 25
CTRL-05	Content safety and AI disclosure	Content filters and Prompt Shields	Profiles per workload; Article 50 disclosure; QA sampling	—	AI Safety lead / AgentOps	Filter config, attack-suite results; per release; Day 60
CTRL-06	Agent authority: only authorized actions execute	Runtime and identity capabilities	Action Policy Service, approvals, idempotency, cumulative cap, kill switch	TMS, billing and carrier APIs honour idempotency keys	Agent product owner / AgentOps	Action–approval correlation, drill record; continuous; Day 15
CTRL-07	Telemetry privacy and audit completeness	Application Insights, Log Analytics, Sentinel	Redaction, prohibited-field scans, 99.5% completeness check	No personal data in support tickets	DPO / Engineering teams	Field scans, completeness query; monthly; Day 25
CTRL-08	Evidence retention and legal hold	Retention and immutability features	RC1–RC6 schedule, legal hold, deletion records	Retain partner evidence per contract	AI Regulatory Counsel + DPO / Security ops	Retention config, disposal record; annual; Day 25

ID	Control and intent	Microsoft	GLC (customer)	Partner	Owner / operator	Evidence; cadence; due
CTRL-09	Cost allocation and quotas	Cost Management; APIM token policies	Tags, chargeback, 70% / 85% alerts, quotas, monthly reconciliation	—	FinOps lead / FinOps analysts	Reconciliation report; monthly; Day 35
CTRL-10	Incident response	Service support only	Runbooks, on-call roles, notification decisions, postmortems	Carrier escalation contacts	Security incident manager / On-call	Exercise record, timelines; semiannual; Day 45

Status at Day 1: all controls Not started; due dates follow the 60-day plan (Table 12). A completed matrix records ownership and gaps; it does not certify GDPR, LGPD, DPDP or EU AI Act compliance.

Regulatory crosswalk (replaces the template's HIPAA crosswalk)

Regime and reference	Obligation	Controls	Owner	Evidence
EU AI Act Art. 50(1)	Tell people they are interacting with an AI system	CTRL-05	CX product owner	Disclosure text, UX test
EU AI Act Art. 6, Annex III	Intended-purpose assessment; reassess on the listed triggers	CTRL-06, 10	AI Regulatory Counsel	Signed assessment
GDPR Arts 5, 22, 32–35	Minimization, storage limits, automated-decision safeguards, security, breach notice, DPIA	CTRL-04, 06, 07, 08, 10	DPO	DPIA, retention config, incident log
LGPD Arts 20, 33–36, 48	Review of automated decisions, international transfers, incident notice	CTRL-04, 06, 10	DPO (Brazil)	Transfer clauses, review records
India DPDP Act and Rules 2025	Notice, purpose limits, breach intimation as provisions take effect	CTRL-04, 08, 10	DPO (India)	Legal review record

Appendix C: Tier 1 role, evidence and escalation matrix

Tier 1 means GenAIOps on-call operators and customer-service leads. Tier 1 never approves actions, changes policy or reads raw content.

Scenario task	Tier 1 permitted action	Evidence available	Stop condition	Approved receiving role	Ownership confirmation
Agent approval-queue triage	Check the attribution record is complete and route the case to the right approver	Decision record, reason codes, amount	Missing identity, policy result or trace ID; restricted flag; amount above USD 2,500	Operations manager; Finance + Legal (dual); customs specialist	Approver accepts in the workflow; timestamp recorded
Circuit-breaker or kill-switch alert	Confirm breaker state; keep the agent in propose-only mode per runbook	Breaker event, affected trace IDs	Any action executed without approval (SEV1)	Security incident manager	Incident commander acknowledges within 15 minutes
Prompt-attack or harmful-output detection	End the session; quarantine the source document; file a redacted description	Content-safety annotations, trace ID	Personal data exposed or more than 5 detections an hour	AI Safety lead; DPO if personal data	Named owner and restricted evidence location recorded
Data-boundary denial	Confirm the gateway denied the request; read routing config only	Gateway policy-denial log	Evidence that data was processed outside the approved zone	DPO + Platform engineering	Receiving owner and next review time recorded
Budget alert or quota breach	Identify the cost driver from token metrics; notify the cost-center owner	Token metrics by app, region and SKU	Break-glass request, or chat degraded to the lower tier	FinOps lead	Exception owner and expiry date recorded
Customer dispute of an agent decision	Log the dispute with the decision ID; tell the customer the review timeline	Decision record, customer message (redacted)	Always escalates	Operations manager not involved in the decision	Review within 10 business days; outcome logged

Production rule: replace these role labels with GLC's approved escalation matrix, and Tier 1 disengages only after the receiving role accepts ownership.

Appendix D: Scenario data package

D1. Service-level objectives and evidence windows (targets from the brief; runbook IDs proposed)

ID	Metric	Target	Window	Severity if breached	Owner	Runbook
SLO-01	Decision-record completeness	≥ 99.5%	Daily	SEV2 below 99.5%; SEV1 below 98%	Platform engineering	RB-ATTR-001
SLO-02	Approval-gate bypass	0	5-minute correlation	SEV1 on any bypass	Security incident manager	RB-AGENT-001
SLO-03	Approved-action success	≥ 99%	24 hours	SEV3 below 99%; SEV2 below 97%	Integration owner	RB-ACTION-001
SLO-04	Critical incident acknowledgement	≤ 15 min	Per incident	Escalate to COO delegate	Security incident manager	RB-IR-001
SLO-05	Autonomous-action containment	≤ 30 min	Per incident	SEV1 continues; council review	AgentOps lead	RB-AGENT-001
SLO-06	Cost allocation coverage	≥ 98% of spend	Monthly	SEV3	FinOps lead	RB-FINOPS-001
SLO-07	Optimization quality guardrail	≤ 2-point decline	Per release	Release blocked	AI product owners	RB-EVAL-001

D2. Data classification

Class	Examples	Allowed telemetry	Access	Prohibited
Customer personal data	Names, contacts, delivery addresses, consignee details	Pseudonymous IDs only	Need-to-know, in-region	Raw values in logs; any use on Global deployments
Shipment and customs documents	Bills of lading, customs declarations, invoices	Document hash, type and size	DocSum users; customs specialists	Raw document text in traces
Financial action data	Credit amounts, reroute costs, approvals	Amounts, reason codes, approver role	Approvers, Finance, audit	Card or bank account details
Operational data	Routes, capacity, carrier performance	Aggregates	Network planners	Driver or customer identifiers
Telemetry metadata	Trace IDs, token counts, latency, error codes	All	Platform, AgentOps, Security	Raw prompts and responses outside RC5

D3. Decisions needed, with the decision taken

ID	Question	Decision and rationale	Approver; evidence
D-01	Global or Data Zone processing per workload?	Data Zone EU/US for personal data; regional Brazil and India; Global only for non-personal NetAssist data (Table 5)	Platform engineering + DPO; boundary test
D-02	When is the agent multiplier retired?	Day 35, after 30 days of traces and 10,000 runs with stable P50 and P95	AgentOps + FinOps; trace report
D-03	How are duplicate actions prevented?	Idempotency key from case ID, action type and parameter hash; downstream APIs reject repeats; partial actions are compensated	Integration owner; replay test
D-04	Which actions are approval-gated?	The brief's authority policy plus a USD 500 per-customer 30-day cap; the agent never auto-denies	Agent product owner, Finance and Legal; authority configuration
D-05	How long is evidence retained?	Record classes RC1–RC6 (Table 7) with legal hold	DPO + AI Regulatory Counsel; signed schedule

References

1. Regulation (EU) 2024/1689 (AI Act), Articles 6, 26, 50 and Annex III: https://eur-lex.europa.eu/eli/reg/2024/1689/oj
2. Regulation (EU) 2026/1744 amending AI Act application dates: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=OJ:L_202601744
3. GDPR Arts 5, 22, 32–35; LGPD Arts 20, 33–36, 48 and ANPD Resolution 15/2024; India DPDP Act 2023 and Rules 2025
4. APIM AI gateway and token policies: https://learn.microsoft.com/en-us/azure/api-management/genai-gateway-capabilities
5. Microsoft Foundry agent tracing: https://learn.microsoft.com/en-us/azure/foundry/observability/concepts/trace-agent-concept
6. Microsoft Foundry deployment types and data zones: https://learn.microsoft.com/en-us/azure/foundry/foundry-models/concepts/models-sold-directly-by-azure-region-availability
7. Azure AI Content Safety and Prompt Shields: https://learn.microsoft.com/en-us/azure/ai-services/content-safety/